BILLU B0X CTF

Vulnerability Assessment & Penetration Testing Report

Victim hostname	indishell.lan
Victim IP address	192.168.31.158
Assessment type	Controlled CTF / intentionally vulnerable lab
Evidence basis	User-supplied screenshots; no additional live testing performed

Confidentiality and scope

Only the victim hostname and victim IP address are retained as target identifiers. Unrelated discovered hosts, IP addresses, names and address-like details are omitted. Password values and any personal credentials are redacted. Evidence images are included where they directly support a finding.

Authorized CTF/lab use only. Do not reproduce these steps against systems without explicit permission.

1. Executive Summary

The supplied screenshots show an exposed legacy web service, a file-parameter endpoint that returned local system files, disclosure of a phpMyAdmin configuration file containing database authentication settings, and a successful SSH session as root. The most consequential issue is the local file disclosure chain, which exposed configuration secrets and was followed by root-level access in the lab.

Finding	Severity	Evidence status
Local file inclusion / sensitive file read via test.php	High	Confirmed in screenshot
phpMyAdmin configuration disclosure	Critical	Configuration contents shown; password redacted
Root SSH access / host compromise	Critical	Successful root shell shown
HTTP service and legacy Apache banner	Medium	Nmap/Nikto evidence
SSH service exposure	Low	Nmap evidence

Evidence limitation: Findings and severity are based only on the provided screenshots. No claim is made that a particular Apache CVE was exploited, and the report does not independently validate whether the disclosed database password is still active.

2. Observed Services

Port	Service / version	Observation
22/TCP	SSH — OpenSSH 5.9p1 Debian 1.4 (Ubuntu Linux)	SSH open; later screenshot shows root login
80/TCP	HTTP — Apache httpd 2.2.22 (Ubuntu)	Web application, directory enumeration and test.php endpoint
80/TCP	Web paths	/phpmy/, /uploaded_images/, /test.php and other paths discovered by Gobuster/Nikto

3. Findings — Kioptrix-style PoC tables

Finding 1 — Local file disclosure through test.php

PORT NO	80/TCP
SERVICE NAME	HTTP — Apache httpd 2.2.22 (Ubuntu)
SEVERITY	High
VULNERABILITY NAME	Local File Inclusion (LFI) / Arbitrary local file read
CVE ID	N/A — application-level issue; no specific CVE established
DESCRIPTION	The supplied terminal evidence shows a POST request to /test.php with the file parameter set to /etc/passwd, and the response contains local account records. A second request to /var/www/phpmy/config.inc.php returned PHP configuration source. This confirms that user-controlled file paths were read by the application.
REMEDIATION	Remove filesystem path input from the endpoint. Use a strict allowlist of logical file identifiers; canonicalize paths and enforce that resolved files remain inside a dedicated non-sensitive directory. Run the web process with least privilege, disable unnecessary PHP features, and add regression tests.
PROOF OF CONCEPT	In the isolated target lab, the screenshot demonstrates the following request pattern: POST /test.php file=/etc/passwd Reproduce only on the authorized CTF VM and capture the HTTP response with sensitive account/configuration data redacted. The supplied screenshot is the primary evidence; avoid dumping additional secrets.



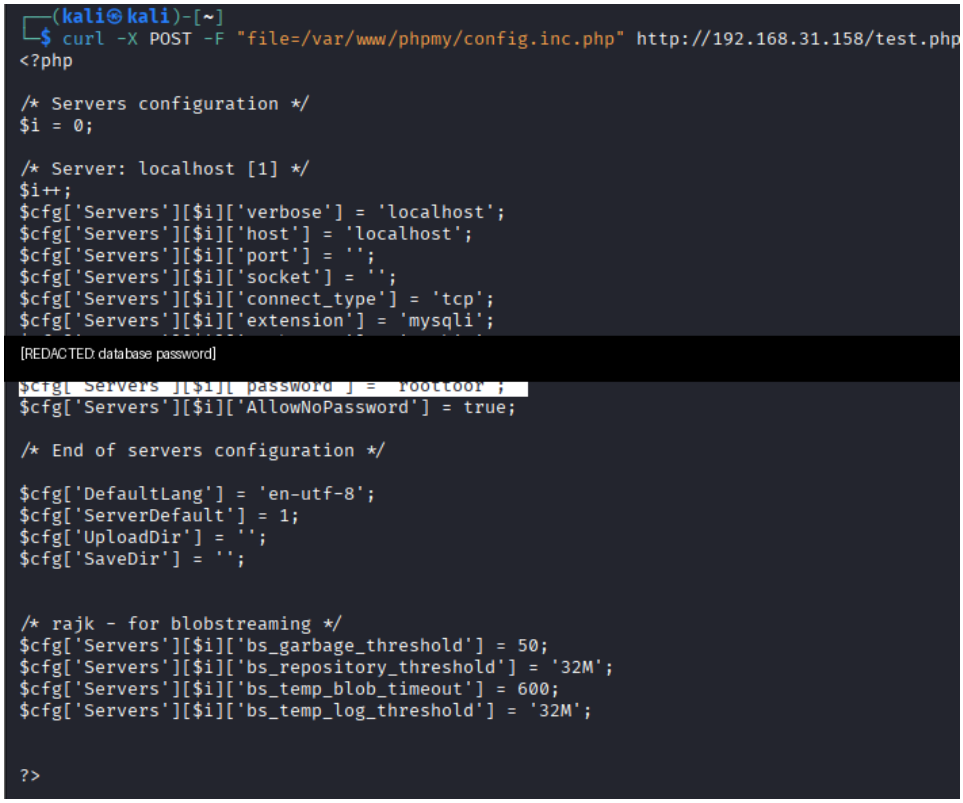
Evidence 1.1 — test.php displays a message indicating that a file parameter is expected.



Evidence 1.2 — request to test.php returns /etc/passwd content; sensitive data is not reproduced in report text.

Finding 2 — phpMyAdmin configuration disclosure

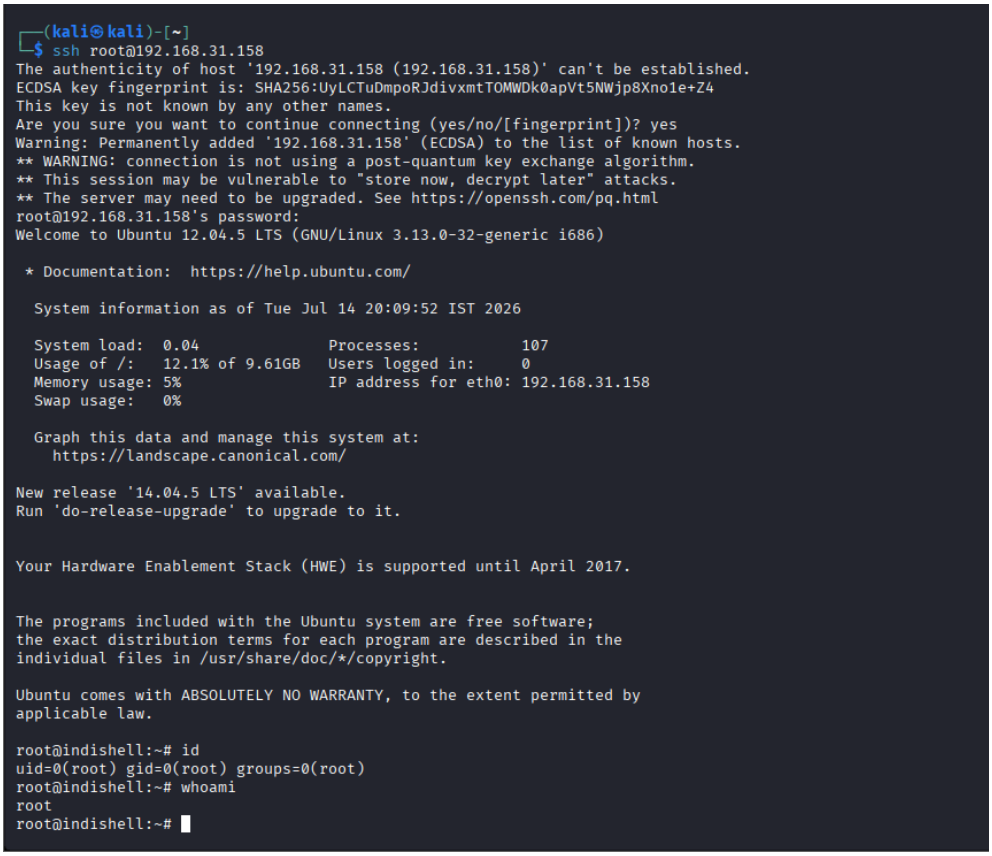
PORT NO	80/TCP
SERVICE NAME	HTTP — Apache / PHP application
SEVERITY	Critical
VULNERABILITY NAME	Sensitive configuration file disclosure / database credential exposure
CVE ID	N/A — configuration exposure; no specific CVE established
DESCRIPTION	A screenshot shows the contents of /var/www/phpmy/config.inc.php returned by the vulnerable file parameter. The file contains database connection settings and a password field. The password value is intentionally redacted from this report.
REMEDIATION	Prevent web requests from reading application configuration files. Store secrets outside the document root; deny HTTP access to configuration and backup files; rotate the exposed database credential; review database access logs; apply least-privilege DB permissions; remove or restrict phpMyAdmin if unnecessary.
PROOF OF CONCEPT	The supplied evidence shows a request to the file parameter for /var/www/phpmy/config.inc.php and PHP source returned in the response. Validate by requesting only the known test file in the isolated lab, then confirm the configuration path is no longer retrievable after remediation. Do not publish the credential value.



Evidence 2.1 — configuration source is visible; the password-bearing line is redacted.

Finding 3 — Root SSH access / host compromise

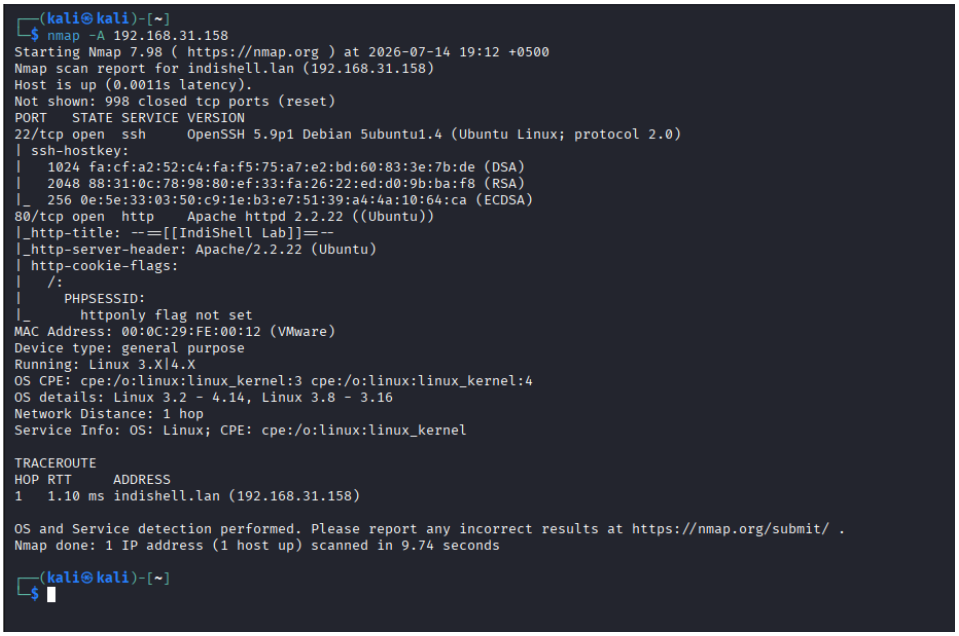
PORT NO	22/TCP
SERVICE NAME	SSH — OpenSSH 5.9p1 Debian 1.4
SEVERITY	Critical
VULNERABILITY NAME	Root account remote access / confirmed privileged compromise
CVE ID	N/A — screenshot confirms access, not a specific SSH software exploit
DESCRIPTION	A supplied screenshot shows a successful SSH session to the victim followed by id output with uid=0(root) and whoami returning root. This proves root-level access was obtained in the lab. The screenshots do not establish whether this resulted from password reuse, credentials recovered through LFI, or another path, so the report does not overstate the exact authentication cause.
REMEDIATION	Immediately rotate exposed credentials and remove direct root SSH login. Use named, non-privileged accounts with key-based authentication and MFA where available. Restrict SSH by source network, update the OS/OpenSSH, review authorized_keys and authentication logs, and investigate persistence.
PROOF OF CONCEPT	Evidence-based validation: connect to the victim SSH service using the authorized lab access path, then run `id` and `whoami`. Expected privileged indicators in the supplied evidence are `uid=0(root)` and `root`. Do not include passwords or private keys in the report.



Evidence 3.1 — SSH session identifies the account as root; no password value is shown.

Finding 4 — Legacy Apache HTTP service and information disclosure

PORT NO	80/TCP
SERVICE NAME	HTTP — Apache httpd 2.2.22 (Ubuntu)
SEVERITY	Medium
VULNERABILITY NAME	Outdated web server / version disclosure and attack-surface exposure
CVE ID	N/A — no specific CVE exploit is demonstrated by supplied evidence
DESCRIPTION	Nmap and Nikto screenshots identify Apache httpd 2.2.22 (Ubuntu). Nikto reports legacy-version concerns, missing X-Content-Type-Options and other web hardening observations, and identifies application paths including /test.php and /images/. These observations support hardening and upgrade recommendations but do not by themselves prove a particular CVE was exploited.
REMEDIATION	Upgrade to a currently supported operating system and Apache release. Remove unnecessary modules and test endpoints, minimize server banners, set X-Content-Type-Options: nosniff, configure secure cookie flags where sessions are used, and retest with a current scanner.
PROOF OF CONCEPT	nmap -sV -sC -p 22,80 192.168.31.158 nikto -h http://192.168.31.158 curl -I http://192.168.31.158/ Run only against the specified lab VM. Preserve output while removing unrelated host identifiers.



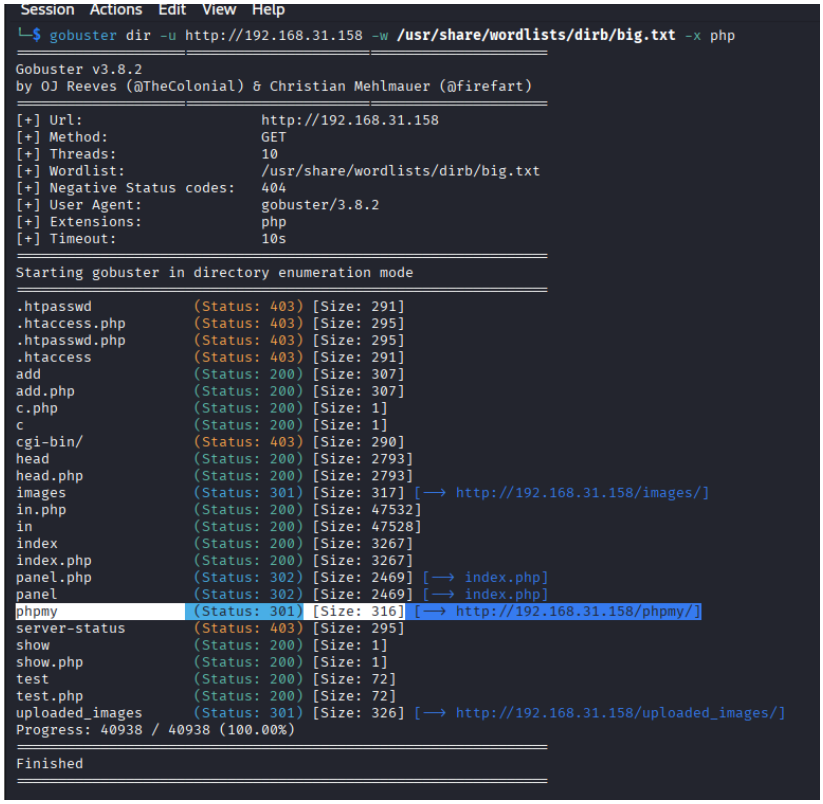
Evidence 4.1 — target service scan; only the victim host details are relevant.



Evidence 4.2 — Nikto output showing legacy Apache version and web hardening observations.

Finding 5 — Web path enumeration

PORT NO	80/TCP
SERVICE NAME	HTTP — Apache / PHP
SEVERITY	Informational to Medium
VULNERABILITY NAME	Discoverable application paths and exposed test/configuration endpoints
CVE ID	N/A
DESCRIPTION	Gobuster identified paths including /phpmy/, /uploaded_images/, /test.php and related PHP endpoints. Enumeration alone is not necessarily a vulnerability, but exposed administration and test endpoints can increase risk; the confirmed file-read behavior is documented separately in Finding 1.
REMEDIATION	Remove unused test/debug endpoints, restrict administrative interfaces to trusted networks, disable directory listing unless required, protect upload directories from script execution, and return consistent authorization-aware errors.
PROOF OF CONCEPT	gobuster dir -u http://192.168.31.158 -w /usr/share/wordlists/dirb/common.txt -x php,txt Review only the in-scope victim. Verify each discovered path manually before classifying it as vulnerable.



Evidence 5.1 — Gobuster directory enumeration results for the victim.

4. Consolidated remediation plan

Priority 1 — Contain and rotate secrets

Rotate database and any reused credentials that may have been exposed. Disable direct root SSH login and review authentication logs and persistence locations. Treat the host as compromised until rebuilt or otherwise verified clean.

Priority 2 — Fix file disclosure

Remove or redesign the file parameter in test.php. Deny access to application configuration, backups and secrets; move configuration outside the web root; apply strict allowlisting and canonical path validation; run the web process with minimum privileges.

Priority 3 — Upgrade and harden services

Upgrade the unsupported legacy OS and Apache/OpenSSH packages to supported releases. Restrict SSH and phpMyAdmin to trusted administrative sources, remove unnecessary endpoints, harden HTTP headers/cookies, and disable script execution in upload directories.

Priority 4 — Retest

Repeat service enumeration and verify that /etc/passwd and phpMyAdmin configuration can no longer be read through the application. Confirm that root SSH login is disabled and only authorized non-root access remains. Capture sanitized evidence for closure.

5. Appendix — sanitized evidence index

Evidence	Screenshot	Use in report
E1.1	Screenshot 2026-07-14 194444.png	test.php expects a file parameter
E1.2	Screenshot 2026-07-14 195525.png	Local file read /etc/passwd and config-path request
E2.1	Redacted copy of Screenshot 2026-07-14 200929.png	Configuration source shown; password line redacted
E3.1	Screenshot 2026-07-14 201005.png	Successful root SSH session
E4.1	Screenshot 2026-07-14 194252.png	Nmap service detection
E4.2	Screenshot 2026-07-14 194344.png	Nikto web server observations
E5.1	Screenshot 2026-07-14 194827.png	Gobuster path enumeration

Redaction note: The database password line is blacked out in the embedded configuration screenshot. Unrelated host-discovery screenshots were not included because they contain out-of-scope hostnames and IP addresses. The browser screenshot hosted on web-security-academy.net was excluded because it does not establish evidence for this Billu b0x target.

Disclaimer

This report documents an intentionally vulnerable CTF environment using only user-supplied evidence. Severity reflects likely impact in the lab and should be validated against the real deployment context before being used as a production risk rating. No additional live tests were performed.